

S BHANU PRAKASH

Cybersecurity Enthusiast — Ethical Hacking & VAPT Practice

Vulnerability Assessment Report

Nessus Essentials — Basic Network Scan of Metasploitable2

Target	Metasploitable2 (intentionally vulnerable lab VM)
Target IP	192.168.44.132 (isolated virtual lab network)
Hostname	metasploitable
Operating System	Linux Kernel 2.6 on Ubuntu 8.04
Tool Used	Tenable Nessus Essentials — Basic Network Scan template
Scan Window	19 minutes
Purpose	Independent practice — automated vulnerability scanning & triage

Note: This assessment was carried out in an isolated personal/virtual lab environment against intentionally vulnerable practice systems, as part of independent cybersecurity skill-building. No production systems, third-party assets, or real organizations were involved or affected.

1. Executive Summary

This report documents a vulnerability scan I performed against a single lab host using Tenable Nessus Essentials (Basic Network Scan template). The target is Metasploitable2, a deliberately vulnerable practice system used for cybersecurity training.

The scan identified 49 findings in total: 4 Critical, 4 High, 6 Medium, 1 Low, and 34 Informational. Several Critical findings show the host can be trivially compromised via known backdoors and default/weak credentials — consistent with an intentionally vulnerable training target.

Overall Risk Rating: CRITICAL

Given the presence of unauthenticated remote-access backdoors and pervasive end-of-life software, this host's security posture is rated Critical for any context other than an isolated training lab.

2. Findings Summary

Severity	Count	% of Total
Critical	4	8.2%
High	4	8.2%
Medium	6	12.2%
Low	1	2.0%
Info	34	69.4%

3. Detailed Findings

Findings are ordered by severity (Critical → Low). Informational findings are summarized in Section 4.

[CRITICAL] 1. UnrealIRCd Backdoor Detection

Affected: Port 6667/tcp (irc) | CVE-2010-2075 | CVSS: 10.0

The remote IRC server is a version of UnrealIRCd shipped with a backdoor allowing an attacker to execute arbitrary code on the affected host.

Recommendation

- Re-download the software, verify it against published MD5/SHA1 checksums, and reinstall.

[CRITICAL] 2. Canonical Ubuntu Linux SEoL (8.04.x)

Affected: Port 80/tcp (www) | CVSS: 10.0

The installed Ubuntu 8.04.x release is no longer maintained by its vendor. With no new security patches, the system likely contains unpatched vulnerabilities.

Recommendation

- Upgrade to a currently supported release of Ubuntu.

[CRITICAL] 3. VNC Server Weak Password

Affected: Port 5900/tcp (vnc) | CVSS: 10.0

The VNC server is secured with a weak password. Nessus authenticated successfully using the password 'password'. An unauthenticated attacker could use this to take control of the system.

Recommendation

- Secure the VNC service with a strong, unique password, or disable it if not required.

[CRITICAL] 4. Bind Shell Backdoor Detection

Affected: Port 1524/tcp (wild_shell) | CVSS: 9.8

A shell is listening on this port without any authentication. Nessus confirmed this by executing the 'id' command and receiving a response confirming root privileges.

Recommendation

- Treat this host as compromised by design (training VM); on any real host, investigate for compromise and reinstall if necessary.

[HIGH] 5. rsh Service Detection

Affected: Port 514/tcp (rsh) | CVE-1999-0651 | CVSS: 7.5

The rsh service passes data between client and server in cleartext and may allow poorly authenticated logins without passwords. It can also enable file-write access via .rhosts or hosts.equiv.

Recommendation

- Disable the rsh service (remove from inetd.conf / systemd) and use SSH instead.

[HIGH] 6. Samba Badlock Vulnerability

Affected: Port 445/tcp (cifs) | CVE-2016-2118 | CVSS: 7.5

The Samba version running is affected by the Badlock flaw in the SAM and LSAD protocols over RPC, allowing a man-in-the-middle attacker to downgrade the authentication level.

Recommendation

- Upgrade Samba to 4.2.11 / 4.3.8 / 4.4.2 or later.

[HIGH] 7. NFS Shares World Readable

Affected: Port 2049/tcp (rpc-nfs) | CVSS: 7.5

The NFS server exports one or more shares without restricting access by hostname, IP address, or IP range.

Recommendation

- Apply appropriate host/IP restrictions on all NFS exports.

[HIGH] 8. ISC BIND Downgrade / Reflected DoS

Affected: Port 53/udp (dns) | CVE-2020-8616 | CVSS: 8.6

The installed ISC BIND 9 version is affected by performance-downgrade and reflected DoS issues due to insufficient limits on referral-response fetches.

Recommendation

- Upgrade to the ISC BIND version referenced in the vendor advisory.

[MEDIUM] 9. ISC BIND Denial of Service

Affected: Port 53/udp (dns) | CVE-2020-8617 | CVSS: 5.9

A specially-crafted message can cause the affected BIND versions to stop responding, resulting in denial of service.

Recommendation

- Upgrade to the patched release closest to the current BIND version.

[MEDIUM] 10. ISC BIND 9.x DoS (Assertion Failure)

Affected: Port 53/udp (dns) | CVE-2020-8622 | CVSS: 6.5

An authenticated remote attacker can trigger an assertion failure while verifying a truncated, TSIG-signed response, causing the server to exit.

Recommendation

- Upgrade to BIND 9.11.22, 9.16.6, 9.17.4, or later.

[MEDIUM] 11. DNS Query ID Prediction / Cache Poisoning

Affected: Port 53/udp (dns) | CVE-2008-1447 | CVSS: 6.8

The DNS resolver does not use randomized source ports for outbound queries, allowing an attacker to poison the cache and redirect legitimate traffic.

Recommendation

- Contact the DNS server vendor for a patch; enable source port randomization.

[MEDIUM] 12. Unencrypted Telnet Server

Affected: Port 23/tcp (telnet) | CVSS: 6.5

Telnet transmits logins, passwords, and commands in cleartext, allowing a man-in-the-middle attacker to eavesdrop or tamper with the session.

Recommendation

- Disable Telnet and use SSH instead.

[MEDIUM] 13. DNS Cache Snooping Information Disclosure

Affected: Port 53/udp (dns) | CVSS: 5.3

The DNS server answers non-recursive queries for third-party domains, potentially revealing which domains have recently been resolved (usage/browsing patterns).

Recommendation

- Restrict the server to only answer recursive queries from authorized clients.

[MEDIUM] 14. SMB Signing Not Required

Affected: Port 445/tcp (cifs) | CVSS: 5.3

SMB message signing is not enforced, allowing a man-in-the-middle attacker to potentially tamper with SMB traffic.

Recommendation

- Enforce SMB signing (Samba: 'server signing' setting).

[LOW] 15. ICMP Timestamp Request Disclosure

Affected: ICMP | CVE-1999-0524 | CVSS: 2.1

The host answers ICMP timestamp requests, disclosing its current system clock, which could assist in defeating time-based authentication.

Recommendation

- Filter outgoing ICMP timestamp replies (type 14) and incoming requests (type 13) at the firewall.

4. Informational Findings (Summary)

The scan also returned 34 informational findings — no direct security risk on their own, but useful for host and service enumeration:

- SMB (multiple issues) — 7 findings, Samba/Windows family
- FTP (multiple issues) — 3 findings, incl. vsftpd detection
- VNC (multiple issues) — 3 findings
- RPC (multiple issues) — 2 findings, incl. NFS share export list
- Nessus SYN Scanner — 25 open ports discovered
- RPC services enumeration — 10 services
- Service detection — 10 services fingerprinted
- Apache banner Linux distribution disclosure
- Backported security patch detection (FTP)
- Common Platform Enumeration (CPE), OS fingerprinting, device type identification
- Ethernet card manufacturer / MAC address detection
- HTTP server type and version banner
- IRC daemon version detection
- PostgreSQL server detection / STARTTLS support
- Samba server and version detection
- SMTP server detection / STARTTLS support
- TCP/IP timestamps supported
- Telnet server detection
- Traceroute information
- VMware virtual machine detection
- DNS BIND version directive disclosure; hostname.bind hostname disclosure (metasploitable)

5. Overall Recommendations

- Isolate this host from any production network — it is intended strictly for lab/training use.
- Remove or disable backdoor services (UnrealIRCd, bind shell on 1524/tcp) if this system is ever repurposed.
- Replace weak/default credentials (e.g. the VNC 'password').
- Disable legacy cleartext protocols (Telnet, rsh) in favor of SSH.
- Patch or upgrade end-of-life software (Ubuntu 8.04, Samba, BIND) if used beyond training purposes.
- Restrict NFS share access and enforce SMB signing.

What I practiced in this exercise

- Configuring and running an authenticated/unauthenticated Nessus Basic Network Scan.
- Reading CVSS scores and CVE references to prioritize remediation.
- Distinguishing exploitable Critical/High findings from purely informational enumeration data.
- Writing clear, actionable remediation guidance for each finding.